

Seguretat Activa

1

Seguretat Activa

La seguretat activa és una part de la seguretat informàtica que comprèn, especialment, les parts de la seguretat que es mantenen sempre alerta i tenen un paper més important en el funcionament del dia a dia del vostre sistema informàtic.

Està més destinada a aturar i minimitzar els atacs que pot patir la vostra màquina. Igualment, té l'objectiu de disminuir els efectes que aquests atacs puguin produir en el vostre sistema informàtic

Que es la seguretat Activa?

És el conjunt de mesures i eines que tenen com a objectiu prevenir danys, disminuir els efectes dels atacs i, en cas que es produeixi un error, recuperar el sistema el més ràpidament possible.

Eines principals

La seguretat activa es basa en l'ús de diferents recursos tècnics:

- **Protecció directa**: Antivirus i programes que controlen el trànsit de dades a la xarxa.
- **Manteniment**: Actualitzacions constants del programari i configuració segura dels sistemes operatius.
- **Prevenció de pèrdues**: Realització de còpies de seguretat (tant de dades com de la configuració).
- **Autenticació**: Ús de certificats digitals i sistemes d'identificació.

Que es la seguretat Activa?

Àmbits d'actuació

Aquesta estratègia actua sobre els punts crítics del sistema:

- **Sistemes i aplicacions**: Mantenint-los vigilats i al dia.
- **Identificació**: Controlant qui accedeix a la informació.
- **Plans de contingència**: Tenir preparat un protocol de resposta davant de fallades o intrusions de virus.

La seguretat activa és la barrera "viva" que busca protegir el sistema abans que passi res i assegurar que pugui tornar a funcionar si hi ha un incident.

Fallades de seguretat: plans de contingència

Els atacs i les intrusions dels hackers poden anar des de la simple obtenció d'informació fins a la supressió de dades o l'apoderament de la màquina.

Igualment, els virus i la resta de programari maliciós poden alentir el funcionament de la màquina, col·lapsar el correu o bé acabar impedint que la màquina funcioni.

Fallades de seguretat: plans de contingència

Heu de tenir en compte que, actualment, disposeu de dos tipus de sistemes operatius, els **sistemes operatius de pagament** i els **sistemes operatius** coneguts com a **programari lliure**.

A part de la diferència que hi ha en la manera de produir cada sistema i del fet que un és de pagament i l'altre no, també hi ha diferències pel que fa a la seguretat i la quantitat de virus.

Fallades de seguretat: plans de contingència

Un cop instal·lat el sistema operatiu, instal·lareu les aplicacions. Una bona mesura de seguretat consisteix a instal·lar només les aplicacions que us facin falta.

Una de les aplicacions que no han de faltar és un **antivirus**.

Que es i com treballa un Antivirus

Antivirus: programa informàtic que intenta identificar, aturar i eliminar virus informàtics i altres tipus de programari maliciós.
Com funciona?

- **Examinar** arxius per buscar-hi virus coneguts que s'ajustin a les definicions recopilades en un diccionari de virus.
- **Identificar** comportaments sospitosos de qualsevol programa informàtic que puguin suggerir una infecció. Aquesta anàlisi pot incloure captures de dades, monitoratge de ports i altres mètodes.

Fallades de Seguretat

Els errors en seguretat poden afectar tant la part del maquinari com la del programari. Predominantment, però, afectaran les dades que teniu guardades en el sistema, ja que seran, en la majoria dels casos, l'objectiu dels possibles atacs externs.

En els servidors, la majoria d'errades de seguretat es produeixen en els serveis d'aplicacions web, les eines d'administració dels servidors i el programari de bases de dades.

És molt important detectar ràpidament un atac per tal de minimitzar-ne els efectes i restaurar el sistema com més aviat millor.

Plans de contingència

Entenem per **pla de contingència** el conjunt de procediments alternatius a l'operativitat normal de cada empresa, la finalitat dels quals és permetre el funcionament de l'empresa fins i tot quan alguna de les funcions deixa d'operar a causa d'algun incident, tant intern com extern a l'organització.

El pla de contingència ha de ser un pla que permeti a l'empresa poder continuar funcionant quan hi ha alguna incidència de seguretat. Alhora, ha de donar instruccions que indiquin com s'ha de resoldre i com s'ha d'actuar.

Plans de contingència

L'elaboració d'un pla de contingència consta de les fases següents:

- Avaluació
- Planificació
- Proves de viabilitat
- Execució
- Recuperació

Utilització de mecanismes per a la verificació de l'origen i l'autenticitat d'aplicacions

Es pot dividir en 3 nivells

Nivell 1: La "Matrícula" i la "Integritat" (Mètodes Clàssics)
Eines bàsiques per saber si el fitxer és el que toca.

- Funcions Hash (MD5, SHA-256): Digues-lis que és com una "empremta dactilar". Si canvies una sola coma del codi de l'app, l'empremta canvia completament.
  - Exemple didàctic: Si jo et dono una caixa i una llista amb el seu pes exacte en mil·ligrams, si quan la reps pesa diferent, saps que algú l'ha obert o hi ha tret alguna cosa.
- Signatura Digital: És el "segell de lacre" del desenvolupador. Garanteix que l'app ve d'una empresa concreta (com Apple, Microsoft o Google) i no d'un desconegut.

Utilització de mecanismes per a la verificació de l’origen i l’autenticitat d’aplicacions

Nivell 2: La "Llista d'Ingredients" (SBOM)
Aquest és un dels mètodes més actuals. Avui dia, ningú escriu una app des de zero; tothom usa peces d'altres (llibreries).

- SBOM (Software Bill of Materials): És com l'etiqueta nutricional d'un aliment.
  - Concepte clau: Si una llibreria externa té un virus, l'SBOM permet al centre educatiu o a l'empresa saber immediatament si les seves aplicacions estan infectades.

Nivell 3: La "Cadena de Custòdia" (SLSA)
Aquest és el nivell més avançat (pronunciat com "Salsa"). Ja no només mirem el fitxer final, sinó tot el camí que ha seguit des de l'ordinador del programador fins al ordinador de l'usuari.

- Traçabilitat: Es generen proves de cada pas (compilació, tests de seguretat, empaquetat). Si un hacker intenta canviar el codi a mig camí, la cadena es trenca i l'aplicació no es pot instal·lar.

Com funciona SLSA

El concepte de SLSA és, en essència, un passaport digital per al programari.

1. Prova d'origen: cada vegada que el codi passa d'una fase a una altra, el sistema genera un document anomenat attestation (atestació). Aquest fitxer conté metadades sobre què s'ha fet, qui ho ha fet i quins materials s'han utilitzat.
2. Segellat criptogràfic: Cada "atestació" es signa amb una clau criptogràfica.
3. "El mur de verificació": Quan l'usuari rep l'aplicació, abans d'instal·lar-la, el teu ordinador fa una comprovació ràpida:
    a. Mira les signatures de tota la cadena
    b. Comprova que les claus siguin de confiança
    c. Si falta una signatura o el codi s'ha alterat "a mig camí", la instal·lació es bloqueja.

Així es veu la cadena a la pràctica:

Pas	Acció	Eina típica
Codi	El programador puja el codi.	GitHub / GitLab
Build	Una màquina aïllada compila el codi.	GitHub Actions / Tekton
Signatura	Es genera el "segell" de seguretat.	Sigstore (Cosign)
Provinença	Es crea el document JSON (atestació).	SLSA Generator
Verificació	L'empresa client comprova el segell abans d'usar-lo.	Policy Controller